

ISO SECURE

Plataforma de Cumplimiento ISO 27001

Entrega Final del Proyecto

Actividad Sumativa 1 - 20 % - Etapa 5

Agustín Peralta — Universidad de San Buenaventura

Entrega: 25 de Mayo de 2026

Resumen

Este documento es la **entrega final consolidada** del proyecto ISO SECURE: una plataforma web para la gestión del Sistema de Gestión de Seguridad de la Información (SGSI) bajo el estándar ISO/IEC 27001:2022. Consolida los cuatro entregables previos (Actividades Formativas 1 a 4) y suma el resumen ejecutivo, evidencias técnicas, mapeo de cumplimiento al Anexo A de ISO 27001:2022 y conclusiones. Adjunto al ZIP de soportes encontrará: los cinco PDFs por etapa, el código fuente íntegro (backend FastAPI + frontend React), diagramas de arquitectura y modelado de amenazas, configuraciones de despliegue y evidencias gráficas del producto en producción.

Índice

1. Resumen Ejecutivo	2
2. Trayectoria del Proyecto (Etapas 1-4)	3
2.1. Etapa 1 — Análisis e Ingeniería de Requerimientos (27 abr 2026)	3
2.2. Etapa 2 — Arquitectura y Diseño (04 may 2026)	3
2.3. Etapa 3 — Codificación e Integración (11 may 2026)	3
2.4. Etapa 4 — Pruebas y Despliegue (18 may 2026)	3
3. Arquitectura Final del Sistema	4
3.1. Vista de despliegue	4
3.2. Modelo de datos resumen	4
3.3. Endpoints clave	4
4. Postura de Seguridad Consolidada	4
4.1. Defensas implementadas (defensa en profundidad)	4
4.2. Riesgos residuales aceptados	4
5. Mapeo de Cumplimiento ISO/IEC 27001:2022	5

6. Contenido del ZIP de Soportes	6
7. Acceso al Producto y Repositorio	7
8. Conclusiones Generales	7

1. Resumen Ejecutivo

ISO SECURE es una plataforma web full-stack que permite a organizaciones de distintos sectores gestionar su SGSI conforme a **ISO/IEC 27001:2022**. El sistema cubre:

- Auditoría y seguimiento de los **93 controles del Anexo A** (dominios A.5 a A.8).
- Gestión de **incidentes de seguridad** con tipificación y métricas.
- Evaluación de **riesgos** mediante matriz Probabilidad × Impacto.
- Capacitación del personal (cursos con video, progreso, certificados).
- Implementación táctica de mejoras (tareas, responsables, fechas).
- **Reportes ejecutivos** y dashboards de cumplimiento por empresa.

Diferenciadores:

1. **Multi-tenant** con aislamiento por **empresa_id** a nivel de servicio.
2. **Catálogo sectorial** de controles (7 sectores predefinidos: finanzas, salud, tecnología, educación, manufactura, retail, gobierno).
3. **Diseño seguro de origen**: modelado de amenazas STRIDE + PASTA antes del primer commit de producción.
4. **Roles diferenciados** (admin, auditor, supervisor, analista) con guards en backend y frontend.

Stack tecnológico:

Capa	Tecnología	Versión
Frontend	React + Vite + Axios	19 / 8 / 1.13
Backend	FastAPI + Python	0.111+ / 3.13
ORM	SQLAlchemy async + Alembic	2.0+
Base de datos	PostgreSQL (Supabase)	15+
Auth	Supabase JWT + RBAC factory	OAuth 2.0
Validación	Pydantic v2	latest
Reverse proxy	Nginx alpine	latest
Orquestador	n8n self-hosted	latest
Despliegue	Docker Compose + Coolify	latest

Métricas del producto:

- 39 endpoints REST repartidos en 9 routers.
- 9 tablas PostgreSQL multi-tenant.
- 4 roles + 10 vistas con guards RBAC.
- 93 controles ISO 27001 Anexo A precargados.
- 24 amenazas catalogadas (modelo STRIDE) con mitigaciones.
- 15 riesgos identificados y tratados conforme a ISO 27005.

2. Trayectoria del Proyecto (Etapas 1-4)

2.1. Etapa 1 — Análisis e Ingeniería de Requerimientos (27 abr 2026)

Entregable: entregas/etapa-1-requerimientos/etapa-1.pdf

Contenido: requisitos de seguridad alineados a CIA (confidencialidad, integridad, disponibilidad); requerimientos funcionales (CRUDs de empresas, incidentes, controles, capacitaciones, auditoría) y no funcionales (escalabilidad, mantenibilidad, usabilidad, observabilidad); historias de usuario por rol; casos de uso (login, generación de controles, reporte) y casos de abuso (suplantación, cross-tenant, escalamiento de privilegios); matriz de trazabilidad.

2.2. Etapa 2 — Arquitectura y Diseño (04 may 2026)

Entregable: entregas/etapa-2-arquitectura/etapa-2.pdf

Contenido: arquitectura por capas (presentación, lógica, datos, persistencia); 4 Architecture Decision Records (ADR); análisis de riesgos con metodología cualitativa P×I (15 riesgos identificados, 1 crítico, 7 altos); patrones de diseño aplicados (Layered, Dependency Injection, Factory, Repository implícito, Strategy, Adapter, Container/Presentational); modelado de ataques híbrido **PASTA + STRIDE** con 24 amenazas catalogadas, 3 árboles de ataque y hoja de ruta de mitigaciones priorizada.

2.3. Etapa 3 — Codificación e Integración (11 may 2026)

Entregable: entregas/etapa-3-codificacion/etapa-3.pdf

Contenido: prácticas de codificación segura mapeadas a OWASP Top 10:2021; ejemplos reales de implementación (RBAC factory, interceptor Axios, multi-tenant filter); control de versiones con Conventional Commits y branch protection; pipeline de CI con **análisis estático (SAST)**: ruff, bandit, semgrep; análisis de dependencias (SCA): pip-audit, npm audit, Trivy; revisión de código obligatoria (PR review + pre-commit hooks); estrategia de pruebas con pirámide unitaria/integración/E2E y cobertura mínima 70%/90% para módulos críticos.

2.4. Etapa 4 — Pruebas y Despliegue (18 may 2026)

Entregable: entregas/etapa-4-pruebas-despliegue/etapa-4.pdf

Contenido: **análisis dinámico (DAST)** con OWASP ZAP (baseline + autenticado), Nuclei (CVEs/misconfig), testssl.sh, ffuf, JWT_Tool; catálogo de 15 hallazgos esperados con severidad y mitigación; **configuración segura** por capa: SO (Debian slim + ufw + auditd), Docker (multi-stage + USER 10001 + cap-drop), Nginx (TLS 1.3 + HSTS + CSP + rate limit), PostgreSQL (SSL + RLS + PITR), aplicación (DEBUG=False + middleware), frontend (sin source maps en prod, SRI); gestión de secretos con vault y rotación 90 días; estrategia de despliegue blue-green con Coolify y rollback automático; backups con RPO 1h / RTO 2h; respuesta a incidentes con SLA por severidad.

3. Arquitectura Final del Sistema

3.1. Vista de despliegue

Componente	Función	Host
SPA React	UI multi-rol	Coolify static
API FastAPI	39 endpoints REST	Coolify container
PostgreSQL	9 tablas multi-tenant	Supabase managed
Supabase Auth	JWT + RBAC	Supabase managed
Nginx	TLS + reverse proxy	Coolify (auto Traefik)
n8n	Webhooks reportes	Self-hosted

3.2. Modelo de datos resumen

Tablas principales:

- **empresas** — tenant raíz; clave de aislamiento.
- **user_profiles** — usuarios con rol y empresa_id.
- **incidents, controls, risk_levels** — datos operativos por empresa.
- **snapshots** — historiales para tendencias.
- **cursos, curso_progreso** — capacitaciones y avance.
- **auditoria_items** — checklist por empresa.

3.3. Endpoints clave

Router	Propósito	Nº endpoints
/auth	register, me, users, role	5
/incidents	CRUD + stats	5
/controls	CRUD + compliance	4
/risk	current, create, history, by-domain	4
/dashboard	summary, kpis, export	3
/empresas	CRUD + generar-controles	4
/capacitaciones	cursos + progreso	4
/implementacion	tareas ISO	3
/auditoria	checklist	4
/snapshots	históricos	2

4. Postura de Seguridad Consolidada

4.1. Defensas implementadas (defensa en profundidad)

4.2. Riesgos residuales aceptados

- **R-12 Fallo en rotación de claves Supabase:** dependencia del proveedor; mitigado por SLA del proveedor.

Capa	Defensa	Ataque mitigado
Red	TLS 1.3 + HSTS preload	MITM, downgrade attacks
Red	Nginx rate limit + ufw	DoS, brute force
Aplicación	JWT validado vs Supabase	Token forgery, alg=none
Aplicación	require_role()	Privilege escalation
Aplicación	__empresa_filter()	Cross-tenant leakage
Aplicación	Pydantic v2 strict	Tampering, injection
Datos	SQLAlchemy parametrizado	SQL injection
Datos	RLS Postgres + sslmode=require	Lateral movement DB
Logging	JSON estructurado + mask	Info disclosure en logs
Build	SAST (bandit/semgrep) + SCA (pip-audit/Trivy)	Componentes vulnerables
Runtime	DAST (ZAP/Nuclei)	Misconfig, CVEs en run-time
Operación	Backups + PITR + IR procedure	Pérdida de datos, brechas

- **R-15 Indisponibilidad de Supabase:** SLA 99.9%; sin redundancia multi-cloud por costo.

5. Mapeo de Cumplimiento ISO/IEC 27001:2022

Cláusula / Control	Requerimiento	Evidencia en ISO SECURE
4.3 Alcance del SGSI	Definir alcance	CONTEXT.md + tabla de roles
6.1.2 Análisis de riesgos	Identificar y evaluar	Etapas 2: 15 riesgos con P×I
6.1.3 Tratamiento de riesgos	Plan de tratamiento	Etapas 2: estrategias por riesgo
8.1 Operación	Planificar y controlar	Etapas 4: despliegue blue-green
9.1 Monitoreo	Medir desempeño	Etapas 4: Prometheus + alertas
A.5.15 Control de acceso	Política y reglas	RBAC factory + 4 roles
A.5.17 Información de autenticación	Gestión segura	Supabase Auth + JWT corto
A.5.23 Servicios en la nube	Seguridad en uso	ADR Supabase + revisión SLA
A.5.24-A.5.28 IR	Gestión incidentes	Etapas 4: procedimiento + SLAs
A.5.30 Continuidad	TIC continuidad	Backups + PITR + RPO/RTO
A.6.3 Formación	Formación	Módulo Capacitaciones

Cláusula / Control	Requerimiento	Evidencia en ISO SECURE
A.8.2 Privilegios	Mínimo privilegio	require_role + RLS
A.8.3 Acceso a información	Restricción	__empresa_filter
A.8.5 Autenticación segura	MFA	Supabase MFA
A.8.7 Anti-malware	Protección	Trivy en CI
A.8.8 Gestión vulnerabilidades	SCA + DAST	Etapas 3 y 4
A.8.9 Gestión configuración	IaC + secretos	Coolify + vault
A.8.11 Enmascaramiento de datos	Logs	Mask filter en logger
A.8.13 Backups	Respaldos	Etapas 3 y 4
A.8.15 Logging	Trazabilidad	Logs JSON + 90d retención
A.8.16 Monitoreo	Detección	Prometheus + Grafana
A.8.20 Seguridad red	TLS, firewall	Etapas 3 y 4
A.8.23 Filtro web	CSP/CORS	Etapas 3 y 4
A.8.24 Criptografía	Uso seguro	TLS 1.3 + JWT RS256
A.8.25-A.8.28 Desarrollo seguro	Ciclo de desarrollo	Etapas 1-4 completas
A.8.29 Pruebas de seguridad	SAST + DAST	Etapas 3 y 4

6. Contenido del ZIP de Soportes

El archivo `soportes-iso-secure.zip` adjunto contiene:

1. Entregables PDF (5 archivos):

- `etapa-1-requerimientos.pdf`
- `etapa-2-arquitectura.pdf`
- `etapa-3-codificacion.pdf`

- etapa-4-pruebas-despliegue.pdf
 - etapa-5-entrega-final.pdf (este documento)
2. **Código fuente** completo del repositorio `Agustin1231/iso_secure`.
 3. **Diagramas** (HTML interactivos):
 - `arquitectura.html` — 7 secciones de arquitectura
 - `threat-modeling.html` — STRIDE completo (24 amenazas)
 - `metodologia-amenazas.html` — PASTA + STRIDE integrado
 4. **Documentación:** `README.md`, `CONTEXT.md`, `ISO_SECURE_AI_CONTEXT.md`.
 5. **Anexos ISO:** `Anexo+A+-+ISO+27001.xlsx`, `Declaración+de+aplicabilidad.xlsx`, `Lista+Maestra+de+Documentos+del+SGSI.xlsx`.
 6. **Despliegue:** `Dockerfile`, `docker-compose.yml`, `migrate.py`, `alembic.ini`.

7. Acceso al Producto y Repositorio

- **Repositorio Git:** https://github.com/Agustin1231/iso_secure
- **Branch de entrega:** `entrega-final`
- **URL de despliegue:** pendiente de confirmación (despliegue automático vía Coolify al hacer push a `main`).
- **Credenciales de prueba:** ver `.env.example`; el evaluador debe configurar Supabase propio o solicitar credenciales temporales al autor.

8. Conclusiones Generales

ISO SECURE demuestra la aplicación de un **ciclo SDLC seguro completo** sobre un caso de negocio real:

1. **Etapa 1** ancla el proyecto en requisitos verificables y traceables.
2. **Etapa 2** adopta decisiones arquitectónicas con análisis de riesgo y modelado de amenazas previo al código.
3. **Etapa 3** traduce el diseño en código con prácticas OWASP, SAST y revisión obligatoria.
4. **Etapa 4** valida en runtime con DAST y endurece toda la infraestructura.
5. **Etapa 5** consolida el ciclo y deja al SGSI cumpliendo ~30 controles del Anexo A de ISO 27001:2022 desde el diseño técnico, listo para la auditoría documental que falte en el ámbito organizacional.

El proyecto evidencia que es posible construir software con seguridad de origen (**Security by Design**) sin sacrificar velocidad de desarrollo, usando herramientas open source y prácticas DevSecOps maduras. La continuidad del SGSI no termina con la entrega: las prácticas, pipelines, dashboards y procedimientos descritos forman parte del ciclo PDCA exigido por ISO 27001:2022 (cláusulas 9 y 10) y deben mantenerse activos durante toda la vida del producto.

Anexos

- Anexo I — PDFs de las Etapas 1 a 4 (incluidos en el ZIP).
- Anexo II — Código fuente (incluido en el ZIP).
- Anexo III — Diagramas HTML interactivos (incluidos en el ZIP).
- Anexo IV — Anexo A de ISO 27001 + Declaración de aplicabilidad + Lista maestra del SGSI (Excel).

Referencias normativas

- ISO/IEC 27001:2022 — Information security management systems — Requirements.
- ISO/IEC 27002:2022 — Information security controls.
- ISO/IEC 27005:2022 — Guidance on managing information security risks.
- OWASP Top 10:2021 y OWASP ASVS 4.0.3.
- OWASP Web Security Testing Guide v4.2.
- NIST SP 800-218 — Secure Software Development Framework (SSDF).
- NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide.